

THREAT ACTOR ANALYSIS

IoT Security Threats for Small and Medium Businesses

Who attacks connected devices in small business environments, how they do it, and what basic controls actually stop them.

PREPARED BY	Marco Helie
AUDIENCE	Small and medium business owners and IT staff
ACTORS COVERED	Organized crime · Nation-state · Opportunistic · Insider

OVERVIEW

Executive Summary

Small and medium-sized businesses are rapidly adopting IoT devices — smart cameras, thermostats, access controls, and other connected equipment — without fully understanding the security risks involved. This report examines four types of threat actors who actively exploit these vulnerabilities: organized cybercriminals, nation-state hackers, opportunistic attackers, and insiders. Each poses distinct risks that can lead to data breaches, ransomware attacks, and operational disruption.

THE FOUR ACTORS AT A GLANCE

ACTOR	PRIMARY MOTIVATION	SKILL AND RESOURCES	MAIN RISK TO AN SMB
Organized cybercriminals	Financial gain	High — service-based tooling	Ransomware and double extortion
Nation-state APT groups	Intelligence and access	Very high — custom malware, zero-days	Prolonged, undetected espionage
Opportunistic attackers	Quick profit, notoriety	Low — pre-built scripts	Botnet conscription, device tampering
Malicious / negligent insiders	Revenge, profit, convenience	Varies — privileged access	Data theft and covert surveillance

01

THREAT ACTOR

Organized Cybercriminal Groups

WHO THEY ARE AND WHAT THEY WANT

Organized cybercriminal groups operate like businesses, with specialized teams handling different parts of their attacks. Their goal is simple: make money. They do this through ransomware, stealing and selling data, or compromising systems to resell access to other criminals. These groups often use "cybercrime-as-a-service" platforms where they can buy or rent hacking tools, making sophisticated attacks accessible even to criminals with moderate technical skills.

HOW THEY OPERATE

These criminals use automated tools to scan the internet for vulnerable IoT devices. Tools like Shodan act as search engines for connected devices, making it easy to find cameras, routers, or smart building controls that have weak security. Once they find a vulnerable device, they will try default passwords (like "admin/admin") or exploit known security flaws to get in.

The real danger starts after they gain access. They do not just stop at the IoT device — they use it as a stepping stone to explore the entire network, looking for valuable targets like file servers, databases, or financial systems. Once they find what they are looking for, they either steal the data or deploy ransomware to encrypt everything and demand payment.

REAL-WORLD SCENARIO

Consider a small accounting firm that installed smart security cameras to monitor their office after hours. The IT person set them up quickly using default passwords, planning to change them later — but that task fell through the cracks. These cameras sit on the same network as the firm's servers containing client tax returns and financial records.

A criminal group scanning for vulnerable devices discovers these cameras within days. They log in using the default credentials they found in online databases. From there, they map out the internal network and locate the file servers. Over the next week, they quietly steal gigabytes of client data — social security numbers, bank account information, tax documents — everything a cybercriminal could want.

Then comes the ransomware. The attackers encrypt all the firm's files and leave a ransom note: pay \$50,000 in Bitcoin or lose access to your data forever. But there is a twist — they also threaten to publish the stolen client data online if the firm does not pay. This "double extortion" tactic puts enormous pressure on the victim, since even if they have backups they still face the exposure of sensitive client information.

WHY THIS MATTERS

The 2016 Mirai botnet showed how devastating IoT attacks can be. Hackers compromised over 600,000 IoT devices using default passwords, then used them to launch massive internet attacks that knocked major websites offline. More recently, the Conti ransomware gang's leaked internal chats revealed they specifically target IoT devices as entry points into business networks. In 2021, hackers breached Verkada's security camera system and accessed 150,000 cameras in hospitals, businesses, and schools, demonstrating that even "secure" IoT platforms can be compromised when credentials are weak.

02

THREAT ACTOR

Nation-State Advanced Persistent Threat Groups

WHO THEY ARE AND WHAT THEY WANT

Nation-state hackers work for governments and have goals beyond making money. They are after intelligence, trade secrets, and long-term access to networks for potential future operations. While small businesses might think they are too insignificant for nation-state attention, that is a dangerous assumption. These groups often target smaller companies that are part of larger supply chains or that work with government contractors, defense firms, or critical infrastructure.

HOW THEY OPERATE

Nation-state actors have serious resources and skills. They use custom-built malware, exploit vulnerabilities that are not publicly known (called "zero-days"), and focus on staying hidden rather than causing immediate damage. They might maintain access to a compromised network for months or even years without being detected.

What makes them particularly dangerous in the IoT context is their patience and creativity. They do not just hack into devices — they sometimes compromise the manufacturers or cloud platforms that

manage those devices, inserting backdoors before the equipment even reaches customers. They can also turn IoT devices into surveillance tools, using security cameras to watch operations or environmental sensors to steal data about manufacturing processes.

REAL-WORLD SCENARIO

A small manufacturing company makes specialized components for aerospace applications. They are a third-tier supplier in a defense supply chain. To improve efficiency, they installed cloud-connected environmental sensors throughout their facility. These sensors monitor temperature and humidity to ensure quality control, constantly sending data to the manufacturer's cloud platform.

A nation-state group interested in defense industry intelligence identifies this company through public research. Instead of attacking well-protected defense contractors directly, they target the sensor manufacturer's cloud platform through a sophisticated phishing campaign against the vendor's employees. Once they compromise the vendor's systems, they can push malicious firmware updates to all connected sensors, including those in the manufacturing facility.

The compromised sensors continue working normally, so nobody suspects anything is wrong. But now they are doing double duty: monitoring environmental conditions while also giving the attackers a hidden foothold in the network. The nation-state group uses this access to intercept internal emails, steal production schedules and technical specifications, and map out the company's relationships with larger defense contractors. This intelligence gathering continues undetected for over a year.

WHY THIS MATTERS

The 2020 SolarWinds hack showed how nation-states exploit trusted platforms to reach thousands of targets simultaneously. Russian hackers compromised SolarWinds' software updates, affecting government agencies and major corporations. While that involved software rather than IoT hardware, the principle is the same: attackers target trusted systems that connect to many organizations.

More directly related to IoT, the 2018 VPNFilter malware campaign compromised over 500,000 routers and IoT devices worldwide. Attributed to Russian military intelligence, this operation showed that nation-states actively target IoT infrastructure for intelligence collection and potential disruption. The malware could survive device reboots and even brick devices on command, demonstrating the strategic value these actors place on controlling IoT systems. Chinese APT groups have similarly targeted industrial IoT systems to gather intelligence about manufacturing processes and supply chains.

03

THREAT ACTOR

Opportunistic Attackers and Script Kiddies

WHO THEY ARE AND WHAT THEY WANT

Opportunistic attackers are the bottom tier of the threat landscape, but they are also the most common. These are amateur hackers, people running pre-built attack scripts, or automated malware that scans constantly for easy targets. Their motivations vary — some want bragging rights in hacker forums, others hope to make quick money through cryptocurrency mining or selling access to compromised systems, and many simply hack because they can.

Despite their low skill level, these attackers pose a real threat because they compensate with sheer volume. They do not carefully select targets — they scan millions of devices looking for anything vulnerable. If your security is weak, you will eventually be found, not because you were specifically targeted but because you happened to be vulnerable when the scan hit your network.

HOW THEY OPERATE

These attackers rely almost entirely on automated tools and pre-written scripts that require minimal technical knowledge. They use tools that automatically try default passwords against common IoT devices, exploit publicly known vulnerabilities, and install ready-made malware for cryptocurrency mining or building botnets.

The barrier to entry is incredibly low. Lists of default passwords for thousands of IoT device models are freely available online. Exploit tools with point-and-click interfaces make launching attacks simple. Even sophisticated malware can be purchased through "malware-as-a-service" platforms for monthly subscription fees.

REAL-WORLD SCENARIO

A small retail store installs smart digital displays throughout the shop to show promotions and product information. These Android-based displays connect to the store's Wi-Fi to receive content updates. The installation technician sets them up with a simple password like "display123" to speed up the process, thinking they will strengthen security later. That "later" never comes.

An automated script scanning for vulnerable devices finds these displays. The script does not know or care what business it is targeting — it is just cycling through every IP address it can reach, trying common passwords. Within seconds, it successfully logs into the displays.

The attacker's script automatically installs malware that turns the displays into part of a botnet used to attack other websites or mine cryptocurrency. The store starts experiencing slow network performance but does not connect it to the seemingly harmless displays. The compromised devices also create a persistent backdoor that more sophisticated attackers could later discover and exploit for worse purposes.

Additionally, the attacker can now change what appears on the displays. Imagine customers seeing inappropriate content, competitor advertisements, or fake "store closing" messages. The reputational damage and customer confusion would be immediate and harmful.

WHY THIS MATTERS

The Mirai botnet started with relatively simple code that scanned for IoT devices with default credentials. Within months, it had infected hundreds of thousands of devices and was used to launch massive attacks that disrupted internet service across the eastern United States in 2016. After the source code was released publicly, countless variations appeared as amateur hackers modified and deployed it.

The Hide and Seek botnet in 2018 specifically targeted IoT devices like IP cameras and routers, spreading automatically once it gained initial access. Despite being relatively unsophisticated, it infected thousands of devices. The Mozi botnet, which emerged in 2019, became one of the largest IoT botnets globally by simply exploiting weak passwords and known vulnerabilities. These examples prove that you do not need sophisticated attackers to face serious threats — automated, low-skill attacks succeed through volume and persistence.

04

THREAT ACTOR

Malicious and Negligent Insiders

WHO THEY ARE AND WHAT THEY WANT

Insider threats come from people who already have legitimate access to your systems — employees, contractors, or recently departed staff. These threats fall into two categories. Malicious insiders deliberately abuse their access, often driven by revenge after termination, financial motivation to sell information, or ideological beliefs. Negligent insiders do not mean harm but create security gaps through carelessness, cutting corners for convenience, or simply not understanding the risks.

In IoT environments, insiders are particularly dangerous because they often have physical access to devices, understand which systems are monitored and which are neglected, and know how to make changes that appear legitimate but create serious vulnerabilities.

HOW THEY OPERATE

Malicious insiders exploit their authorized access to avoid triggering security alarms designed to catch external attackers. They know organizational routines, understand where the blind spots are, and can time their activities to minimize detection risk. Their techniques include reconfiguring IoT devices to send data to external servers they control, installing unauthorized devices that look legitimate but serve malicious purposes, deliberately weakening security settings to help external accomplices, or using IoT monitoring capabilities to gather sensitive information for sale.

Negligent insiders create problems through different means. They might fail to change default passwords despite policies requiring it, connect personal smart devices to corporate networks without permission, disable security features that interfere with convenience, or improperly dispose of old IoT devices without wiping credentials and configuration data.

REAL-WORLD SCENARIO — THE MALICIOUS INSIDER

A medical clinic deploys smart security cameras and electronic access controls throughout the facility to protect patient areas and control access to medication storage and medical records. These systems connect to the same network as their electronic health records, billing systems, and appointment scheduling.

The clinic recently fired an IT administrator who felt his termination was unfair. This person had deep knowledge of the clinic's systems and security setup. Before leaving, while still having legitimate access, he reconfigured several security cameras to secretly forward video feeds to an external server he controlled. He also created hidden administrator accounts on the access control system and documented all the network details and passwords he could access.

After his termination, this former employee maintains surveillance of the clinic through the compromised cameras and periodically accesses the network through the backdoors he created. He contacts the clinic's competitors offering to sell patient records and proprietary business information, and monitors the security systems to understand when the clinic is most vulnerable.

REAL-WORLD SCENARIO — THE NEGLIGENT INSIDER

A receptionist at the same clinic buys a smart speaker for the front desk using petty cash. She thinks it will be helpful for setting timers, playing background music, and maybe even helping with scheduling. She connects it to the clinic's Wi-Fi without telling IT staff. This device has weak security settings and connects to her personal cloud account.

The voice-activated device now sits in the reception area continuously listening to conversations. It captures discussions about patients, passwords spoken aloud during password resets, sensitive business conversations, and confidential information — all being transmitted to cloud servers outside the clinic's control and potentially accessible to the manufacturer, to anyone who compromises the employee's personal account, or through a breach at the cloud provider.

WHY THIS MATTERS

Healthcare facilities have seen repeated incidents of staff members misusing security camera systems to spy on colleagues or patients, exploiting their authorized access for unauthorized surveillance. While many insider threat cases do not directly involve IoT, they demonstrate the danger of trusted access being abused.

Shadow IT — unauthorized devices employees connect to corporate networks — represents an ongoing insider threat driven by convenience rather than malice. Employees frequently bring in smart speakers, personal security cameras, fitness trackers, and other IoT devices to work environments, creating unmanaged vulnerabilities that security teams never anticipated defending against.

The challenge with insider threats is that traditional security measures designed to keep outsiders out do not work when the threat comes from someone who is already inside with legitimate credentials and system knowledge.

SYNTHESIS

Understanding the Real Risks

WHAT ALL THESE THREATS HAVE IN COMMON

Despite their different motivations and skill levels, all four threat actor types exploit the same fundamental weaknesses:

Default credentials. Most IoT devices ship with simple default passwords that users rarely change. Attackers maintain comprehensive databases of these defaults.

Missing updates. IoT devices typically receive few security updates, and organizations often do not realize these devices need patching just like computers.

Poor network design. Businesses frequently put IoT devices on the same networks as critical systems, allowing attackers to move from a compromised camera to sensitive databases.

No monitoring. IoT devices rarely appear in security monitoring, creating blind spots where attackers operate undetected.

Physical access. Many IoT devices lack physical security, allowing anyone in the building to manipulate them.

WHAT THIS MEANS FOR YOUR BUSINESS

The consequences of IoT security failures are serious and tangible:

Ransomware attacks. Criminals enter through IoT devices, then encrypt all your business data and demand payment. Ransom demands routinely reach six figures, and paying does not guarantee you will get your data back or avoid having stolen information published.

Data breaches. IoT devices provide access to networks containing customer information, financial records, and confidential business data. Breaches trigger regulatory fines, legal liability, notification costs, and permanent reputational damage.

Operational disruption. Attackers can disable critical IoT-dependent functions like climate controls, access systems, or automated processes, shutting down operations until systems are restored.

Espionage. Compromised cameras, microphones, and sensors let attackers spy on your operations, stealing trade secrets and competitive advantages.

Legal liability. If your compromised devices are used to attack others, you could face lawsuits from affected parties.

THE "TOO SMALL TO TARGET" MYTH

Many small business owners believe they are too insignificant to attract cybercriminal attention. This is dangerously wrong for several reasons. Organized criminals use automated scanning that finds vulnerable systems regardless of company size. Nation-state actors target small companies in supply chains to reach larger targets. Opportunistic attackers do not choose victims — they compromise whatever they find. Insiders have access regardless of company size.

The belief that IoT devices are low-risk because they do not store sensitive data misses the point. Attackers do not want the devices themselves — they want the network access, surveillance capabilities, and disruption potential these devices provide.

RECOMMENDATIONS

What You Should Do

Protecting IoT devices does not require expensive solutions or expert knowledge. Basic security practices eliminate most risks.

1. **Change all default passwords** immediately when deploying new devices. Use strong, unique passwords for each device.
2. **Put IoT devices on separate networks** isolated from systems handling sensitive information. This prevents lateral movement after a compromise.
3. **Keep firmware updated** by checking for security updates regularly and applying them promptly.
4. **Know what is connected** by maintaining an accurate inventory of all IoT devices. You cannot protect what you do not know exists.
5. **Monitor IoT traffic** to detect unusual behavior that might indicate compromise.
6. **Check vendor security** before buying IoT devices. Choose vendors committed to providing security updates and responsible disclosure.

7. **Train your staff** about IoT-specific risks and proper security practices, including the dangers of connecting unauthorized devices.
8. **Conduct security assessments** that include IoT devices in vulnerability scans and penetration tests.

CLOSING Conclusion

The convenience and efficiency IoT devices bring to business operations are real and valuable. But these benefits come with security responsibilities that cannot be ignored. The threats are not theoretical — organized criminals, nation-state actors, opportunistic attackers, and insiders actively exploit IoT vulnerabilities every day.

The good news is that fundamental security practices — changing default passwords, segmenting networks, applying updates, and monitoring activity — dramatically reduce risk. The bad news is that many businesses skip these basics, treating IoT devices as simple appliances that do not need security attention.

The choice is yours: address these vulnerabilities proactively with straightforward security measures, or wait until an incident forces you to deal with the much more costly and painful consequences of a breach. The attacks described in this report are not hypothetical scenarios — they are happening right now to businesses just like yours. The only question is whether you will be ready when they find you.

SOURCES References

- Antonakakis, M., et al. (2017). *Understanding the Mirai botnet*. Proceedings of the 26th USENIX Security Symposium, 1093–1110.
- Greenberg, A. (2021). *Hackers breach thousands of security cameras, exposing Tesla, jails, hospitals*. Wired.
<https://www.wired.com/story/verkada-hack-cameras-jails-factories-tesla/>
- Krebs, B. (2016). *DDoS on Dyn impacts Twitter, Spotify, Reddit*. Krebs on Security.
<https://krebsonsecurity.com/2016/10/ddos-on-dyn-impacts-twitter-spotify-reddit/>
- National Security Agency & CISA. (2021). *Chinese state-sponsored cyber operations: Observed TTPs*. Joint Cybersecurity Advisory.
- Verizon. (2024). *2024 Data Breach Investigations Report*. Verizon Enterprise Solutions.
- Zetter, K. (2020). *The untold story of the boldest supply-chain hack ever*. Wired.